# ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

**Cisco Industrial Ethernet 4010 Switch (classic IOS 15.2)** · Component type: **Network Device (NDR) - industrial Ethernet switch** · Target SL = SL 3

| | |
|---|---|
| **Where to work** | **Classic IOS CLI** via console and **SSHv2**; **HTTPS Device Manager** (web GUI) / Express Setup for day-0; RADIUS/TACACS+ (ISE). Review with `show` commands (read-only); `archive` for config change tracking. |
| **Ports / paths** | **SSH 22**; **HTTPS 443** (Device Manager); **Telnet 23** + **HTTP 80** (must be OFF); **SNMPv3 161**; RADIUS 1812/1813; TACACS+ 49; NTP 123; Syslog 514. Physical: RJ45 **console**, **USB**, **SD flash** card, **Express Setup** button, alarm I/O; DIN-rail/IP30. No RESTCONF/NETCONF (classic IOS). |
| **Firmware / license** | Classic IOS **15.2(x)EC / 15.2(x)E**. Certificate-based **MACsec** requires **15.2(8)E+**. Confirm model/version with `show version`; confirm the running image is a Cisco digitally-signed image (`show software authenticity running`). |
| **CLI syntax (classic IOS — differs from IOS-XE)** | This is **classic IOS**, not IOS-XE (Catalyst 9300 / IE3300 / Stratix 5800). MACsec verify = `show macsec interface <if>` + `show mka sessions` (the `show macsec summary` short-form is IOS-XE only). 802.1X sessions = `show authentication sessions` (the IOS-XE alias `show access-session` does **not** exist here). Image trust = `show software authenticity running` / `show software authenticity keys` (there is **no** Trust-Anchor `show platform hardware authentication` and **no** `show file integrity`). Change audit = `show archive log config all` (**not** `show log config all`). Local users = `show running-config \| include username` + `show users` (no `show local user accounts`). No RESTCONF/NETCONF/`show switch` stack commands. |
| **How to read** | Default read-only (`show` commands). Each row = native CLI/Device-Manager step-by-step + command-level external-tool validation + pass. Write/exploit tools = isolated/representative env + written authorization. Never run intrusive tests on a live control ring. |

**Session setup & evidence handling**

**Do this BEFORE running any command** so the evidence is complete, attributable, and protected:
**1. Start a full session log first. PuTTY:** Session › Logging → select **All session output** → set **Log file name** (browse to the encrypted evidence folder) → under "if the log file already exists" pick **Always append** → tick **Include header** and (Logging › Options) **Flush log frequently**; put `&Y&M&D_&T` in the name for an auto timestamp. (SecureCRT: File › Log Session; Tera Term: File › Log; macOS/Linux: `script -a <file>.log` or `ssh user@host | tee <file>.log`.)
**2. Name the file to the evidence convention** (one file per device): `<site>_<zone>_<assetTag>_<vendor>_<model>_<mgmtIP>_<YYYYMMDD-HHMM>_<testerInitials>.log`.
**3. Disable paging** so full output is captured (it resets each login): disable paging: `terminal length 0` (also `terminal exec prompt timestamp` to stamp each command); restore with `terminal length 24` when done.
**4. Self-document the log** - capture identity/time first: `show clock` then `show version`, so the file proves what/when/who.
**5. Close out:** restore paging, stop the log (PuTTY closes it when the session ends), and verify the file opened/saved.
**6. Protect the evidence file.** It contains running-config and may hold hashes, SNMP community strings, or keys: store **only** on the encrypted assessment share, follow the project data-classification/retention policy, redact secrets before sharing, and **never** email it in cleartext. **Do not save the device password in the PuTTY/SecureCRT saved session** - authenticate interactively or via the approved password manager.

## FR 1 — Identification & Authentication Control (IAC)

| Req (3-3 / 4-2) | Requirement | Where & how to verify (native steps + Ext. tools) | Pass criteria / evidence | Notes / license |
|---|---|---|---|---|
| **SR/CR 1.1** | Human user I&A | Confirm AAA is on: `show run \| sec aaa` shows `aaa new-model` + `aaa authentication login default group tacacs+ local`. SSH-only: `show ip ssh` (v2); lines `transport input ssh` with **no** `transport input telnet`; `no ip http server` + `ip http secure-server`.<br>**Test:** console/SSH/Device Manager without creds -> denied; Telnet/HTTP refused.<br>**Ext. tools:** `ssh -v admin@<sw>`; `nmap -p 22,23,80,443 <sw>` (only 22/443 answer); RADIUS/TACACS+ test client (ISE). | All mgmt interfaces authenticate; invalid creds rejected; no Telnet/HTTP/anonymous path. | Telnet+HTTP off for SL-3. |

| Req (3-3 / 4-2) | Requirement | Where & how to verify (native steps + Ext. tools) | Pass criteria / evidence | Notes / license |
|---|---|---|---|---|
| **SR/CR 1.2** | Device & software-process I&A | Port authentication: `show authentication sessions` / `show dot1x all` for **802.1X / MAB**; switch-to-switch **certificate-based MACsec** (15.2(8)E+): `show mka sessions` / `show macsec interface <if>` - MKA/PMK static (manual) or dynamic (RADIUS). SNMP requires v3 auth. **Test:** a rogue endpoint on an 802.1X port lands in the restricted/guest VLAN or is denied. **Ext. tools:** 802.1X test supplicant + rogue device; Wireshark filter `eapol \|\| mka`; ISE live logs. | Only authenticated devices/peers connect; unknown endpoints quarantined; MACsec up on trunks. | Cert-MACsec needs 15.2(8)E+ and NTP-synced CA/ISE. |
| **SR/CR 1.3** | Account management | Named accounts + privilege: `show run \| sec username\|aaa`; AAA-managed identities, distinct privilege levels, **no shared/default** accounts (no bare `username cisco`). **Ext. tools:** TACACS+/ISE account export; `show users`. | Individually attributable, least-privilege, lifecycle-managed accounts; no shared logins. | |
| **SR/CR 1.4** | Identifier management | Confirm unique user identifiers (`show run \| incl username`) and a unique device identity (hostname + chassis serial from `show version` / `show inventory`); no reuse across switches. **Ext. tools:** Config review; `show inventory`; asset inventory. | Unique user and device identifiers; no reuse. | |
| **SR/CR 1.5** | Authenticator management | `service password-encryption` on; secrets type 8/9 where supported: `enable secret` and `username x privilege 15 secret` - **no** type-0/7 (`show run \| incl secret\|password`). Manage SSH keys/certs. **Ext. tools:** Config grep for weak hash types; `ssh-audit <sw>`. | Strong password hashes; no cleartext/type-7; keys/certs rotate. | |
| **SR/NDR 1.6** | Wireless access management | **N/A.** Wired industrial switch with no native wireless interface; wireless is managed at the network layer. **Ext. tools:** Confirm no WLAN interface on the platform. | N/A - justification recorded (wired network device). | N/A |
| **SR/CR 1.7** | Strength of password auth | Verify the configured policy with `show running-config \| include security passwords` (shows `security passwords min-length`) and `show running-config \| section aaa` (any `aaa common-criteria policy` with min-length/complexity/lifetime). Enforce a strong policy locally (`security passwords min-length 14` + `aaa common-criteria policy`) or via ISE/AAA. **Ext. tools:** `show running-config \| include security passwords`; `show running-config \| section aaa`; ISE/AAA policy screenshot. | Configurable strong password policy enforced (local or AAA). | |
| **SR/CR 1.8** | Public key infrastructure (PKI) certificates | `show crypto pki certificates` for CA-signed device certs (Device Manager/802.1X/MACsec); `show ip ssh` for KEX/host-key/cipher strength; strong RSA(>=2048)/ECC. **Ext. tools:** `sslscan <sw>:443` / `testssl.sh https://<sw>`; `ssh-audit <sw>`. | CA-signed certs, strong keys/ciphers; weak/expired rejected. | |
| **SR/CR 1.9** | Strength of public key-based authentication | Confirm public-key authentication uses strong, current keys/algorithms. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.8** above (shared steps); confirm this requirement individually and adjudicate it separately. | Strength of public key-based authentication verified individually. | |
| **SR/CR 1.10** | Authenticator feedback | Confirm password/secret entry is not echoed in cleartext at the CLI or Device Manager login, and `service password-encryption` hides stored strings in `show run`. **Ext. tools:** Visual verification (CLI/GUI); `show run` (no cleartext passwords). | Authenticators obscured during entry and in config. | |
| **SR/CR 1.11** | Unsuccessful login attempts | Login throttling: `login block-for 100 attempts 3 within 60` + `login on-failure log`; AAA/ISE lockout. Verify `show login`. **Ext. tools:** Hydra/Medusa (ISOLATED, authorized) to confirm quiet-mode/lockout engages. | Excess failures trigger lockout/quiet-mode and are logged. | |
| **SR/CR 1.12** | System use notification | Login banner on all paths: `banner login` / `banner motd` (also on Device Manager). Confirm the approved notice at console/SSH/GUI. **Ext. tools:** Console/SSH; browser (HTTPS); `show run \| incl banner`. | Approved system-use banner on all mgmt interfaces. | |
| **SR/NDR 1.13** | Access via untrusted networks | Restrict mgmt: `line vty 0 15` with `access-class MGMT in`, a dedicated mgmt VLAN/OOB, `control-plane` protection; SSH-only; MFA via ISE for remote. No mgmt reachable from process/untrusted VLANs. **Test:** from an untrusted VLAN, reach 22/443 -> must fail. **Ext. tools:** `nmap -Pn -p 22,443,161 <sw>` from each VLAN; ACL review. | Mgmt-plane unreachable from untrusted networks; MFA for remote admin. | |

## FR 2 — Use Control (UC)

| Req (3-3 / 4-2) | Requirement | Where & how to verify (native steps + Ext. tools) | Pass criteria / evidence | Notes / license |
|---|---|---|---|---|
| **SR/CR 2.1** | Authorization enforcement | Command authorization: `aaa authorization commands 15 default group tacacs+` and/or role-based CLI `parser view`; privilege levels.<br>**Test:** a low-priv user cannot enter config or run privileged clear/show.<br>**Ext. tools:** TACACS+ command-authorization logs; login as a low-priv account. | Least privilege enforced; unauthorized commands denied and logged. | |
| **SR/CR 2.2** | Wireless Use Control | **N/A.** No wireless interface on this device; wireless access is managed at the network layer. | N/A - justification recorded (not assessed as a control). | N/A |
| **SR 2.3** | Use Control for Portable and Mobile Devices | **N/A.** Device does not host portable/mobile-media use; USB/portable-device use is controlled at the engineering host (EWS). | N/A - justification recorded (not assessed as a control). | N/A |
| **SR/NDR 2.4** | Mobile code | **N/A / limited.** Classic IOS on the IE4010 has no general-purpose app-hosting/mobile-code runtime; confirm only the signed IOS image runs and no untrusted TCL/EEM scripts are loaded.<br>**Ext. tools:** `show run \| sec event manager` (review any EEM scripts); confirm no untrusted scripts. | No general-purpose mobile code; only signed IOS + reviewed scripts run. | NDR-specific. |
| **SR/CR 2.5** | Session lock / timeout | Idle timeout on all lines: `line con 0` / `line vty 0 15` -> `exec-timeout 10 0`; `service tcp-keepalives-in`.<br>**Ext. tools:** Manual idle test; `show run \| sec line` | Idle sessions time out on console and vty. | |
| **SR/CR 2.6** | Remote session termination | View/terminate sessions: `show users` + `clear line vty <n>` / `disconnect ssh <n>`; bound concurrent access with `line vty 0 15` + `session-limit` and `ip ssh maxstartups`; idle sessions close via `exec-timeout`.<br>**Ext. tools:** `show users` / `show ssh`; Wireshark (session teardown). | Sessions terminable on demand and on inactivity; concurrency bounded. | |
| **SR/CR 2.7** | Concurrent session control | Confirm concurrent sessions are bounded/limited and monitored. **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.6** above (shared steps); confirm this requirement individually and adjudicate it separately. | Concurrent session control verified individually. | |
| **SR/CR 2.8** | Auditable events | AAA accounting + config-change logging: `aaa accounting commands 15 default start-stop group tacacs+`; `archive` -> `log config` -> `logging enable / notify syslog`.<br>**Test:** change config -> syslog + `show archive log config all` entry with the username.<br>**Ext. tools:** Syslog server; `show logging` | Login/config/command events logged with user + timestamp. | |
| **SR/CR 2.9** | Audit storage capacity | Size + offload logs: `logging buffered <size> informational` plus central `logging host`; confirm behavior if the syslog server is unreachable (local buffer retained, SNMP/health alert) so events are not silently lost.<br>**Ext. tools:** `show logging` (buffer size/use); SIEM source-silent alert. | Logs sized/offloaded; audit-failure alerting defined; events not lost. | |
| **SR/CR 2.10** | Response to audit processing failures | Confirm a defined response to audit-processing/forwarding failures (alerting; no silent loss). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.9** above (shared steps); confirm this requirement individually and adjudicate it separately. | Response to audit processing failures verified individually. | |
| **SR/CR 2.11** | Timestamps | `service timestamps log datetime msec localtime show-timezone`; authenticated NTP: `ntp authenticate` + `ntp authentication-key` + `ntp server <ip> key <n>` (also required for cert-based MACsec).<br>**Ext. tools:** Wireshark `ntp`; `show ntp status` / `show ntp associations` | Accurate authenticated time; logs carry synced timestamps. | |
| **SR/CR 2.12** | Non-repudiation | AAA command accounting + config archive record the **username** per change; confirm in `show archive log config all` and TACACS+ logs.<br>**Ext. tools:** TACACS+ accounting review. | Every change attributable to a named user. | |
| **NDR 2.13** | Physical & diagnostic interfaces | Control physical interfaces: locked cabinet; secure the **console**; disable/limit **USB**; protect/remove the **SD flash**; guard the **Express Setup** button (a long press can factory-reset - restrict physical access); shut unused ports.<br>**Ext. tools:** Physical inspection; `show inventory`; confirm USB/SD access controlled. | Physical/diagnostic interfaces controlled; Express Setup button protected. | NDR-specific. |

## FR 3 — System Integrity (SI)

| Req (3-3 / 4-2) | Requirement | Where & how to verify (native steps + Ext. tools) | Pass criteria / evidence | Notes / license |
|---|---|---|---|---|
| **SR/CR 3.1** | Communication integrity | Mgmt via SSH/HTTPS/SNMPv3 (auth+priv) only; data-plane integrity via **MACsec** on trunks/uplinks; `control-plane` policing. No cleartext mgmt (no Telnet/HTTP/SNMPv1-2c). **Ext. tools:** Wireshark (encrypted mgmt; MACsec on links); `nmap -p 23,80,161 <sw>` (closed). | All mgmt/data integrity-protected; cleartext protocols disabled. | |
| **SR/NDR 3.2** | Protection from malicious code | Digitally-signed Cisco IOS: `show software authenticity running` and `show software authenticity keys`; load only Cisco-signed images from CCO; verify `verify /md5 flash:<image>` before `boot system`. **Ext. tools:** Image signature/hash cross-check vs Cisco.com; `show software authenticity running` | Only Cisco-signed IOS runs; image authenticity verified. | NDR-specific. |
| **SR/CR 3.3** | Security functionality verification | Compare running-config to the hardened baseline; protect + hash the image; `configure replace flash:baseline` from a trusted archive; detect drift. **Ext. tools:** Config diff vs baseline; RANCID/Oxidized; `verify` | Config matches baseline; image integrity verified; drift detected. | |
| **SR/CR 3.4** | Software & information integrity | Confirm software & information (config/program) integrity; unauthorized change prevented/detected. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.3** above (shared steps); confirm this requirement individually and adjudicate it separately. | Software & information integrity verified individually. | |
| **SR/CR 3.5** | Input validation | Confirm the control plane tolerates malformed/oversized frames without instability: CoPP + hardening protect the CPU. **ISOLATED only:** fuzz mgmt/protocol stacks on a bench switch and watch CPU/CoPP drops. **Ext. tools:** Protocol fuzzer (ISOLATED); `show policy-map control-plane` drop counters; `show processes cpu` | No instability on malformed input; CoPP absorbs/blocks. | |
| **SR/CR 3.6** | Deterministic output | **N/A.** A switch does not drive a physical process output; deterministic/fail-safe output is a device-layer control. Confirm the configured behavior of ports/links on failure (UDLD, err-disable) is deliberate. **Ext. tools:** `show udld` / `show interfaces status err-disabled` (defined failure behavior). | N/A - justification recorded (network device). | N/A |
| **SR/CR 3.7** | Error handling | Confirm graceful error handling without info leak: `show logging` / crashinfo review; err-disable recovery configured; no sensitive data in banners/SNMP. **Ext. tools:** `show logging`; `show errdisable recovery` | Graceful error handling; no crash-loop or info leak. | |
| **SR/CR 3.8** | Session integrity | SSH/TLS protect against hijack/replay; disable weak SSH algos: `ip ssh server algorithm encryption aes256-ctr` / `mac hmac-sha2-256` / `kex` (strong only); `ip ssh version 2`. **Ext. tools:** `ssh-audit <sw>`; `sslscan <sw>:443` | Strong session crypto; SSHv1/weak algorithms disabled. | |
| **SR/CR 3.9** | Protection of audit information | Protect logs: restrict who can `clear logging` (command authorization), send syslog over a protected path where supported, and lock down the SIEM store. **Ext. tools:** TACACS+ authz on clear-logging; syslog transport review; SIEM access review. | Audit records protected from unauthorized read/modify/delete. | |
| **NDR 3.10** | Support for updates | Signed IOS upgrade via `archive download-sw` / `copy scp: flash:` then `boot system flash:<image>`; keep the prior signed image for rollback; verify authenticity before reload. **Ext. tools:** Lab upgrade/rollback test; `verify` + `show software authenticity running` post-upgrade. | Signed updates with a tested rollback image; authenticity verified. | NDR-specific. |
| **NDR 3.11** | Physical tamper resistance/detection | Locked cabinet; control console/USB/SD/Express Setup button; tamper evidence in syslog + `show logging`; seal where required. **Ext. tools:** Physical inspection (locks/seals); `show logging` for unexpected reloads/config changes. | Physical access controlled; tamper logged. | NDR-specific. |
| **NDR 3.12** | Provisioning product-supplier roots of trust | Cisco image signing is the supplier root of trust: the switch runs only Cisco digitally-signed IOS and `show software authenticity keys` shows the Cisco signing keys; an unsigned/tampered image fails authenticity. **Ext. tools:** `show software authenticity running` / `show software authenticity keys`; attempt an unsigned image (isolated) -> authenticity fail. | Supplier signing root intact; unsigned/tampered images rejected. | NDR-specific. |
| **NDR 3.13** | Provisioning asset-owner roots of trust | Asset owner provisions its own trust: install the enterprise CA for Device Manager/802.1X/MACsec (`crypto pki trustpoint` + enrollment); manage the trust list. **Ext. tools:** `show crypto pki trustpoints` / `show crypto pki certificates`; confirm enterprise CA enrolled, defaults replaced. | Asset-owner CA provisioned and enrolled; trust list managed. | NDR-specific. |

| Req (3-3 / 4-2) | Requirement | Where & how to verify (native steps + Ext. tools) | Pass criteria / evidence | Notes / license |
|---|---|---|---|---|
| **NDR 3.14** | Integrity of the boot process | Classic IOS verifies the **Cisco digitally-signed image** at load (`show software authenticity running`); confirm only signed IOS boots. Note the hardware secure-boot anchor is limited vs IOS-XE - document the residual.<br>**Ext. tools:** `show software authenticity running` + `show version` (image/rommon). | Signed-image boot verified (HW anchor limited - documented residual). | NDR-specific. |

## FR 4 — Data Confidentiality (DC)

| Req (3-3 / 4-2) | Requirement | Where & how to verify (native steps + Ext. tools) | Pass criteria / evidence | Notes / license |
|---|---|---|---|---|
| **SR/CR 4.1** | Information confidentiality | SNMPv3 priv (AES), SSH/HTTPS/MACsec; disable SSHv1 + weak ciphers/KEX; TLS 1.2 on Device Manager.<br>**Ext. tools:** `sslscan <sw>:443` / `testssl.sh`; `ssh-audit`; Wireshark. | Modern TLS/SSH ciphers; SNMPv3 priv; weak protocols disabled. | |
| **SR/CR 4.2** | Information persistence | On decommission/RMA, wipe config + credentials: `write erase` / `delete /force flash:` (certs/keys, vlan.dat, config), remove/erase the **SD flash**, and clear the startup so nothing sensitive is recoverable.<br>**Ext. tools:** `write erase` + reload; confirm SD removed/sanitized. | Config, keys, and certs purged on decommission or reuse. | |
| **SR/CR 4.3** | Use of cryptography | Confirm use of modern cryptography (strong suites, managed keys; weak/legacy disabled). **Steps:** for this product this is assessed with the same evidence as **SR/CR 4.1** above (shared steps); confirm this requirement individually and adjudicate it separately. | Use of cryptography verified individually. | |

## FR 5 — Restricted Data Flow (RDF)

| Req (3-3 / 4-2) | Requirement | Where & how to verify (native steps + Ext. tools) | Pass criteria / evidence | Notes / license |
|---|---|---|---|---|
| **SR/CR 5.1** | Network segmentation | VLAN/PVLAN + ACL segmentation isolate cell/zone; `show vlan brief`, `show access-lists`, private-VLAN config; unused ports in a black-hole VLAN + `shutdown`.<br>**Ext. tools:** `nmap -sT -p- <host>` across VLANs; ACL review. | Effective segmentation; inter-zone flows restricted to policy. | |
| **SR/NDR 5.2** | Zone boundary protection | ACLs / CoPP at boundaries; VTY `access-class`; `show policy-map control-plane`. Only required flows cross the boundary.<br>**Ext. tools:** Nmap at boundary; ACL/CoPP review. | Boundary enforces least-flow; control-plane protected. | |
| **SR/NDR 5.3** | General-purpose person-to-person comms restrictions | **N/A.** Network switch with no general-purpose person-to-person messaging.<br>**Ext. tools:** Confirm no such services on the switch. | N/A - justification recorded. | N/A |
| **SR 5.4** | Application Partitioning | **N/A.** Single-purpose device; no separable applications to partition (handled at the host/SCADA layer). | N/A - justification recorded (not assessed as a control). | N/A |

## FR 6 — Timely Response to Events (TRE)

| Req (3-3 / 4-2) | Requirement | Where & how to verify (native steps + Ext. tools) | Pass criteria / evidence | Notes / license |
|---|---|---|---|---|
| **SR/CR 6.1** | Audit log accessibility | Central syslog: `logging host <server>` + `logging trap informational`; `show logging` readable/exportable by authorized staff.<br>**Ext. tools:** Syslog server; log export. | Logs centralized and accessible/exportable to authorized users. | |
| **SR/CR 6.2** | Continuous monitoring | Ship syslog + SNMPv3 traps to the SIEM; where supported `flow`/NetFlow to a collector; monitor CoPP/security counters; a passive OT IDS on a SPAN port gives ring visibility.<br>**Ext. tools:** Syslog listener (`nc -lu 514`); passive OT IDS; SIEM. | Logs/flows/traps monitored; alerting on security events. | |

## FR 7 — Resource Availability (RA)

| Req (3-3 / 4-2) | Requirement | Where & how to verify (native steps + Ext. tools) | Pass criteria / evidence | Notes / license |
|---|---|---|---|---|
| **SR/CR 7.1** | Denial-of-service protection | Control-plane policing (CoPP), `storm-control`, `ip dhcp snooping`, dynamic ARP inspection, `spanning-tree bpduguard`, `switchport port-security`. Verify `show policy-map control-plane`. **Ext. tools:** Traffic generator / flood (ISOLATED); `show policy-map control-plane` counters. | Switch stays manageable/forwarding under storm; protections active. | |
| **SR/CR 7.2** | Resource management | Monitor `show processes cpu sorted` + `show processes memory sorted` and TCAM (`show sdm prefer`); enforce rate limits at boundary. **Ext. tools:** SNMP/telemetry monitoring. | CPU/memory/TCAM within bounds under peak; no exhaustion. | |
| **SR/CR 7.3** | Control system backup | Config archive: `archive` + `path` + scheduled save; back up via SCP; recover with `configure replace` or reload from archive; test on a spare. **Ext. tools:** SCP backup; `sha256sum` of config; lab restore. | Recent verified config backup; restore/rollback tested. | |
| **SR/CR 7.4** | Control system recovery & reconstitution | Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately. | Control system recovery & reconstitution verified individually. | |
| **SR 7.5** | Emergency Power | **N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer. | N/A - justification recorded (not assessed as a control). | N/A |
| **SR/CR 7.6** | Network & security config settings | Document + baseline all security settings; capture in the archive; changes via change control (`show archive`). **Ext. tools:** RANCID/Oxidized baseline compare. | Settings documented, baselined, change-controlled. | |
| **SR/CR 7.7** | Least functionality | Disable unused services: `no ip http server`, Telnet, `no cdp run` where not needed, `no ip source-route`, `no service pad`, `no ip bootp server`; `shutdown` unused ports; SNMPv3-only. **Ext. tools:** `nmap -sTU -p- <sw>` (open services); config review. | Only required services/ports enabled; insecure services disabled. | |
| **SR/CR 7.8** | Component inventory | `show version`, `show inventory`, `show license` capture model, IOS version, license, and SFP/module info. **Ext. tools:** ReadOnlyEnum; passive OT monitor. | Complete model/version/license inventory captured. | |

## External Test Tools — how to use

| Tool / method | Verifies | How to use — steps / example | Constraints |
|---|---|---|---|
| **Console / SSH (classic IOS CLI)** | Native config review (all) | Authenticated CLI via console or SSHv2; run `show` commands read-only with a least-privilege account. | Read-only; no changes on production. |
| **Device Manager (HTTPS)** | Config review via browser (1.1, 4.x) | Browse Device Manager over HTTPS; review users, banner, certificate, services; Express Setup for day-0 only. | HTTPS only; authorized account. |
| **RADIUS / TACACS+ (ISE)** | AAA authn/authz/accounting (1.1, 2.1, 2.8) | Test identities; verify authentication, command authorization, accounting in server logs. | Test identities; review logs. |
| **nmap** | Port/service exposure & segmentation (1.1, 1.13, 5.x, 7.7) | `nmap -sT -p 22,23,80,443,161 -T2 <sw>`; scan from each VLAN to prove segmentation; confirm 23/80 closed. | Tune timing on production. |
| **sslscan / testssl.sh** | Device Manager TLS strength (1.8, 3.8, 4.3) | `sslscan <sw>:443` / `testssl.sh https://<sw>`; strong ciphers, valid cert; weak protocols off. | Read-only/safe. |
| **ssh-audit** | SSH algorithm strength (1.5, 1.8, 3.8, 4.3) | `ssh-audit <sw>`; strong KEX/cipher/MAC; SSHv1/weak algos disabled. | Read-only. |

| Tool / method | Verifies | How to use — steps / example | Constraints |
|---|---|---|---|
| **Wireshark / tcpdump** | Comm integrity, MACsec, monitoring (1.2, 3.1, 6.2) | SPAN/tap; confirm mgmt encrypted, MACsec on trunks, EAPOL/MKA on 802.1X ports; inspect NTP. | Passive; SPAN/tap only. |
| **802.1X supplicant / rogue device** | Port authentication (1.2) | Present authorized then unauthorized endpoints on an 802.1X/MAB port; confirm grant + rogue quarantine. | Coordinate with NAC team. |
| **Syslog/SIEM + passive OT IDS** | Audit & monitoring (2.8, 6.1, 6.2) | Confirm logs/command-accounting arrive; passive OT IDS for ring visibility; trigger an event and verify. | Coordinate with SIEM team. |
| **RANCID / Oxidized** | Config integrity & drift (3.3, 3.4, 7.6) | Automated config capture; diff running-config vs the hardened baseline. | Read-only. |
| **Hydra / Medusa** | Login lockout behavior (1.11) | Authorized repeated SSH/Device-Manager logins to confirm login-block/quiet-mode engages. | ISOLATED/authorized only. |
| **Traffic generator** | DoS resilience (7.1) | Storm/flood to confirm CoPP/storm-control keep the switch manageable/forwarding. | ISOLATED; authorization. |
| **Nessus / OpenVAS** | Known-CVE scan (3.2, general) | Authenticated scan for IOS CVEs; cross-check Cisco PSIRT. | ISOLATED/representative; authorization. |

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.